

Threat Mitigation Strategy and Risk Management Evaluation for Webb For U

Risk Management Strategy

Abstract

The report assesses Webb For U's cybersecurity protection after a series of security breaches, which led to hackers accessing Microsoft SQL database servers and spreading harmful advertising material through reliable online networks. The investigation discovered multiple vulnerabilities that affected the organisation, including weak password practices, insufficient monitoring, ineffective security controls, and poor access management. The organisation used unsafe practices to secure portable storage devices, and they failed to apply their existing security measures correctly. The report studies current threat actor techniques, which include their work in malvertising campaigns, rogue antivirus distribution, SQL server attacks and insider threat operations.

The organisation evaluates its current cybersecurity plan by comparing it to established industry standards, which include ISO/IEC 27001, the NIST Cybersecurity Framework, CIS Critical Security Controls and MITRE ATT&CK. The organisation has two sections which show effective practices, while they still have major security weaknesses which expose them to higher risks of operational interruptions, financial losses and damage to their reputation.

The organisation will improve its security measures through a 12-month threat reduction plan, which will implement multiple technical security measures, administrative procedures and operational methods. The recommendations include improvements to identity and access management, network monitoring, endpoint protection, database security, staff awareness training, insider threat management, and incident response capabilities. The report includes a financial implementation plan which establishes priorities to distribute cybersecurity costs throughout the year while first addressing the most important security risks. The report aims to assist Webb For U in creating a cybersecurity framework which will prevent security breaches and help the organisation regain trust from its stakeholders.

Table of Contents

Introduction.....	4
1. Current Threat Actor Landscape.....	5
1.1 Malvertising and Advertising Platform Abuse.....	5
1.2 Rogue Antivirus and Social Engineering Techniques.....	5
1.3 Microsoft SQL Server Exploitation.....	6
1.4 Insider Threat Exposure.....	6
2. Evaluation of the Current Cyber Security Plan.....	7
2.1 Governance and Policy Enforcement.....	7
2.2 Password Management and Access Control.....	7
2.3 Network Monitoring and Detection Capabilities.....	8
2.4 Database and Server Security.....	8
2.5 Insider Threat and Data Protection Controls.....	9
2.5.1 Incident Response and Recovery Planning.....	9
3. Recommended Threat Mitigation Strategy.....	10
3.1 Critical Controls: Months 1 - 3.....	10
3.2 Medium-Term Controls: Months 4 - 8.....	10
3.3 Long-Term Controls: Months 9 -12.....	11
3.4 Financial and Resource Considerations.....	12
3.4.1 Initial Investment Requirements (Months 1 - 3).....	12
3.4.2 Infrastructure and Technical Control Costs (Months 4 - 8).....	13
3.4.3 Ongoing Operational and Recurring Costs (Months 9 - 12).....	13
3.4.4 Cost–Benefit and Strategic Risk Perspective.....	13
3.5 Twelve-Month Cyber Security Cash Flow Forecast.....	13
4. Continuous Improvement, Compliance, and Future Threat Preparedness.....	15
4.1 Security Audits and Compliance Monitoring.....	15
4.2 Staff Training and Awareness Programs.....	15
4.3 Future Threat Intelligence Integration.....	15
4.4 Metrics and KPIs for Security Effectiveness.....	16
Conclusion.....	17
References.....	18
Appendix A – Immersive Labs Evidence.....	19

Introduction

Webb For U is a digital advertising company that provides promotional materials and online advertising services to small and medium-sized businesses. The organisation purchases advertising space through Google AdWords and displays its promotional banners on popular websites that receive high visitor traffic. The company has built strong partnerships with Pinterest and Reddit, which it uses to serve as a reliable advertising intermediary that connects advertisers with online audiences.

The organisation has recently lost most of its reputation because of multiple cybersecurity breaches that occurred in the past. The attackers gained access to the company's Microsoft SQL database servers, which they used to alter client advertisements without authorisation. The modified advertisements led users to websites that contained rogue antivirus malware, which specifically targeted Windows laptop users. The resulting malware outbreak infected thousands of people, which caused Webb For U to suffer damage to its reputation and face potential legal problems and financial losses.

The external cybersecurity consultancy performed an internal investigation, which found that the organisation had fundamental deficiencies in its security governance systems. The main results showed that employees failed to follow IT security policies, used poor password methods, operated removable media in dangerous ways, together with improper internet usage, and did not monitor their network activities, while their web servers and database systems lacked proper security supervision. The investigation found that one employee used company equipment to collect personal data, which created two problems for the organisation because it showed employees who worked inside the company had access to critical information, and the organisation failed to protect its sensitive data. The organisation needed to address both its technical, structural and procedural risks, which enabled attackers to gain access to its systems.

This report examines the present cybersecurity framework, which defends the organisation from both new security threats and current cyber-attack techniques. The report will evaluate existing security measures while pinpointing both effective practices and operational gaps to recommend security enhancements based on established security standards. The proposed mitigation strategies will undergo both priority assessment and cost evaluation, which will distribute expenses across a twelve-month timeframe to aid budget forecasting.

The report aims to assist Webb For U in transitioning from its existing reactive security framework towards a systematic security solution which employs risk assessment techniques to defend against all potential security threats.

1. Current Threat Actor Landscape

1.1 Malvertising and Advertising Platform Abuse

The cybercrime ecosystem has gained malvertising as a profitable method for conducting attacks. Threat actors increasingly use legitimate advertising networks to distribute malware through trusted platforms which they hijacked. Malvertising campaigns have been widely documented in recent threat intelligence reports (ENISA, 2023; Verizon, 2024). Attackers need to breach advertising intermediaries because they can launch attacks through their advertising supply chains to reach thousands of users who visit the compromised website.

Malvertising operations have existed since attackers targeted popular sites like Pinterest and Reddit, which shows that a site's reputation does not protect it from danger. Attackers use established platforms to build trust with users, which helps them spread malware. Users who see advertising banners that contain malicious code will be sent to exploit kits and fake software downloads without receiving any advanced notice.

The attack pattern of Webb For U shows a typical malvertising attack that starts with internal advertising system breaches and proceeds to banner content manipulation before attackers redirect users to fake antivirus sites, resulting in widespread Windows device infections. The “Kyle and Stan” malvertising campaign, which was identified in 2015, is another well-known example of malvertising attacks. In this attack, the attackers were successful in taking over the advertising networks and placing their malicious ads on well-known websites. As a result, when users visited those websites, the ads would redirect them to an exploit kit that would attempt to install malware or fake antivirus software on their computers. Thousands of users were estimated to be infected each day as the attackers took advantage of the advertising supply chain and the trust people have for well-known websites. This is an example of how an advertising supply chain can be used to distribute malware to users' computers, which is similar to the attack presented in the Webb For U scenario (Malwarebytes, 2016). The attack type requires financial gain, which drives its developers to create automated systems that generate thousands of infections within hours after their infrastructure becomes operational.

The strategic implication is significant. Webb For U functions as an advertising intermediary which connects digital advertising networks with their advertising supply channels. The organisation functions as a service provider, but if security measures are not properly established, it will become a potential malware distribution centre. Intermediaries serve as prime targets for threat actors because they offer both operational scale and a legitimate appearance to their victims.

1.2 Rogue Antivirus and Social Engineering Techniques

Rogue antivirus software continues to operate as a permanent security threat which has existed through multiple historical periods. The execution of these campaigns depends on psychological manipulation methods because their technical capabilities do not reach advanced levels. Users receive deceptive security warnings which indicate their systems have been infected, which compels them to install fake security software. The malware gains access to the victim's system after installation, which enables it to steal payment information and launch extra destructive programs and create ongoing system access.

The success of these campaigns depends heavily on:

- User trust in the source of the advertisement
- Lack of endpoint protection
- Absence of content validation controls
- Insufficient browser security configurations

The Webb For U attack targeted Windows laptop users because the attackers had intentionally selected their target group. Windows systems remain the dominant enterprise and consumer operating environment, making them a high-return target for financially motivated actors.

The attackers showed their professional expertise by choosing an advanced distribution method which directly targeted a specific group of victims.

1.3 Microsoft SQL Server Exploitation

The Microsoft SQL database servers reached their current state because hackers exploited the system's fundamental weaknesses through their attacks. The SQL infrastructure of a system faces multiple security risks from attackers who use these methods to gain unauthorised access.

The first threat to SQL infrastructure emerges from the SQL injection vulnerabilities which exist in web applications (OWASP, 2021).

The second threat to SQL infrastructure emerges from weak administrator credentials, which fail to provide sufficient protection.

The third threat to SQL infrastructure emerges from unpatched server software, which creates security vulnerabilities.

The fourth threat to SQL infrastructure comes from remote services, which have been left unsecured.

The fifth threat to SQL infrastructure results from network segmentation, which has been implemented poorly.

The attackers used database monitoring and logging systems to gain access to sensitive data while conducting their operations. The absence of effective server monitoring within the Webb For U system monitoring increased the time required for security breaches to be detected. Early detection enables organisations to respond effectively to security threats which exist in today's threat environment, according to current security practices. The organisation became vulnerable to attacks because it failed to establish continuous log monitoring and intrusion detection systems, which created an unmonitored area for security breaches.

1.4 Insider Threat Exposure

The research demonstrated that employees used company equipment for unauthorised purposes, which enabled them to access personal information. Cybersecurity experts consider insider threats to be the most complicated and least recognised danger because they need to defend against both outside attackers and inside personnel who have valid access to systems and their operational procedures.

The incident demonstrates:

- The system lacks proper access control systems, which need to be enforced
 - The organisation does not monitor activities that operate with special access rights
 - The organisation implements insufficient measures to protect against data breaches
-
- The organisation shows inadequate controls which need to separate job responsibilities

Insider threats present a risk that shows governance failures under risk management because it extends beyond technical weaknesses. Organisations face two security threats when they fail to enforce internal policies because it creates pathways for both internal security breaches and external security attacks from malicious insiders.

2. Evaluation of the Current Cyber Security Plan

2.1 Governance and Policy Enforcement

The inquiry found that Webb For U had written formal security policies; however, the organisation failed to implement those security measures into their regular operations. The situation shows a failure in governance because there is no existing documentation to demonstrate the evidence. Information security management systems, according to ISO/IEC 27001, require organisations to establish their security policies together with dedicated leadership and system accountability and methods to achieve ongoing development (ISO, 2022). The organisation lacks enforcement mechanisms, which results in weak control systems and deficient executive supervision.

The organisation demonstrates a reactive maturity level because it lacks established monitoring systems and assurance procedures according to risk management standards. The National Institute of Standards and Technology Cybersecurity Framework demands organisations to combine governance with their Identify and Protect security functions (NIST, 2018). Webb For U did not establish cybersecurity governance which matches its business goals because employees engaged in dangerous activities, and the organisation did not conduct compliance audits.

The absence of well-established accountability frameworks demonstrates that organisational leadership fails to maintain proper control over its responsibilities. Research shows that organisations need executive leadership together with performance assessment metrics to achieve effective cybersecurity governance (Von Solms & Van Niekerk, 2013). Policies lose their power as actual regulations when there exists no active monitoring system. The organisation's governance system failed because of its inherent weaknesses, which created multiple security vulnerabilities that allowed outside attacks and internal data breaches to occur.

2.2 Password Management and Access Control

The organisation showed weak credential management practices, which allowed attackers to perform brute-force attacks and credential stuffing attacks and gain unauthorised access to

systems through privilege escalation. The organisation did not provide any proof that it had put multi-factor authentication (MFA) systems, privileged account restrictions or access recertification procedures into practice.

NIST SP 800-63B requires multiple authentication methods, but the current system lacks these requirements, which serve as vital protection against credential-based security breaches (NIST, 2017). The organisation fails to establish role-based access control (RBAC) systems, which leads to security violations of least-privilege requirements according to CIS Critical Security Controls standards (CIS, 2021).

The access control model needs to establish separate duties while managing user access rights from the beginning to the end of their employment. The Microsoft SQL infrastructure breach occurred because attackers obtained privileged credentials which either had weak security or were used across multiple systems without proper safeguards. Academics maintain that credential abuse stands as the primary method through which hackers gain initial access to enterprise networks. The organisation has established a fundamental identity governance weakness which represents more than a single technical problem.

2.3 Network Monitoring and Detection Capabilities

The primary vulnerability discovered by the evaluation team stemmed from their failure to implement ongoing surveillance together with central system monitoring. The attackers maintained control over their operations for an extended period because they used their ability to transform advertisement material and access database systems without being detected.

The NIST Cybersecurity Framework's Detect function requires organisations to establish ongoing security monitoring systems that can identify security breaches (NIST 2018). Webb For U system infrastructure lacked Security Information and Event Management (SIEM) solutions, structured log analysis capabilities, and established incident response procedures. The current situation demonstrates unprofessional detection engineering processes that restrict the organisation's ability to handle security incidents.

The combined use of intrusion detection systems with automated alerting systems reduces the severity of security breaches, according to research conducted by Scarfone and Mell (2007). The organisation lost its ability to control the security breach because it did not establish any monitoring systems, which resulted in a complete protective failure. The system operated in a reactive mode because it detected attacks only after attackers had already completed their work.

2.4 Database and Server Security

The Microsoft SQL Server breach demonstrates how system defences, patching procedures and network design methods need to be strengthened. The organisation did not implement any security measures, such as vulnerability assessments, automated update systems or web application firewalls.

NIST SP 800-53 establishes secure configuration management and vulnerability remediation as essential technical security measures (NIST 2020). The failure to keep systems updated with security patches creates a situation where attackers can exploit system vulnerabilities. ISO/IEC 27001 requires organisations to implement systematic processes for managing risks, which are essential for safeguarding their vital resources.

The organisation suffered greater damage because it failed to implement proper network segmentation. The system used for public access lacked proper protection, which allowed attackers to move between different parts of the network. The system design flaw shows how the organisation failed to implement proper defence processes. The database functions as a revenue-generating asset for business continuity; therefore, its security breach shows the company failed to align its security measures with the importance of its assets.

2.5 Insider Threat and Data Protection Controls

The organisation operated without any monitoring systems that tracked privileged user activities, protected against data breaches or detected user behaviour patterns that deviated from normal behaviour.

The insider threat literature identifies monitoring of high-risk accounts and enforcement of segregation of duties as essential countermeasures (Greitzer & Frincke, 2010). The research which Carnegie Mellon University conducted at its CERT Insider Threat Centre demonstrates that both malicious and negligent insiders exploit weak governance structures to conduct their attacks (CERT, 2021).

The organisation violates accountability principles by lacking both audit logging and access traceability, which are required by ISO/IEC 27001 standards. The organisation needs monitoring systems which will help it identify different types of policy breaches and system misuse. The insider threat risk becomes highly dangerous because it allows unauthorised users to access internal systems while possessing detailed knowledge about the organisation's operational procedures. The results reveal that the system for managing trust and privileged access control has experienced an operational breakdown.

2.5.1 Incident Response and Recovery Planning

The existing governance systems, access control systems and monitoring systems of Webb For U need an established incident response system with a recovery plan. The organisation has discovered security weaknesses but does not have a written process to handle security breaches. The incident response plan will establish the duties of personnel and create methods for team members to communicate, and it will develop procedures for problem escalation. The recovery process must contain data recovery methods, system separation procedures and techniques to collect digital evidence. Staff members will learn their responsibilities through regular tabletop exercises and simulations, which will help them handle threats from both internal and external sources. The organisation can achieve better operational performance through process standardisation, which will help it prevent cybersecurity attacks and build stronger defences against future incidents.

3. Recommended Threat Mitigation Strategy

3.1 Critical Controls: Months 1 - 3

The threat mitigation plan design, which security experts developed for Webb For U, needs to be executed throughout its twelve-month duration because its initial risk controls will provide immediate protection while creating sustainable security solutions for future operations. The first quarter requires organisations to improve their governance systems while they enforce existing policies, manage user identities and oversee their network security systems. IT security policies need to undergo complete examination because organisations must verify their complete alignment with ISO/IEC 27001:2022 standards and NIST Cybersecurity Framework (ISO, 2022; NIST, 2018) requirements. Employees will maintain IT security policy compliance because formal accountability systems and reporting procedures to upper management will operate alongside planned compliance audits (Von Solms & Van Niekerk, 2013; Peltier, 2016). The creation of a risk registers which connects to business goals needs to happen because organisations require this tool to manage cybersecurity risks throughout their entire operation, while it also helps them address governance weaknesses found during internal investigations (NIST, 2018).

Identity and access management needs urgent resolution. The organisation must implement multi-factor authentication (MFA) for all administrative and remote accounts to decrease the risk of credential exploitation according to CIS Critical Security Controls v8 and NIST SP 800-63B guidelines (CIS, 2021; NIST, 2017). The organisation requires role-based access control (RBAC) implementation to maintain least-privilege access rights, while access recertification processes will eliminate unnecessary user accounts (Sandhu et al., 1996; ISO, 2022). The organisation will resolve its earlier identified security issues by implementing these security measures.

The implementation of a Security Information and Event Management (SIEM) solution will establish log centralisation, which allows for real-time alerts and boosts detection capabilities throughout web servers, database systems and internal network infrastructure, according to NIST CSF 2018 and Scarfone and Mell 2007. Staff should receive training in detection engineering and incident escalation procedures to ensure that anomalous activities are identified and responded to promptly (CIS, 2021). The current method protects against extended attacker presence, which served as a major reason for the previous security breach.

3.2 Medium-Term Controls: Months 4 - 8

The organisation should implement its database and server security enhancements together with its endpoint protection system and insider threat defence system during the medium-term period, which lasts from the fourth month until the eighth. It needs to establish secure SQL servers and web application servers by implementing CIS Critical Controls 4 and 5 while developing automated patch management systems to protect system security

(CIS, 2021; NIST SP 800-53, 2020; Krebs, 2014). Organisations should establish network segmentation to protect web-facing servers from internal databases since this measure decreases any potential security breach impact (ISO, 2022). The organisation needs to deploy advanced endpoint protection tools, which will help detect rogue antivirus campaigns and malvertising attacks, while content validation and filtering mechanisms for outbound advertising banners will help decrease malware propagation risks (Symantec, 2019; ENISA, 2020). The essential staff training program requires employees to learn how to identify social engineering methods, together with various malware detection methods (Hahnagy, 2018).

The current stage requires enhanced protection against insider threats. The implementation of Privileged Access Management (PAM) systems together with behavioural analytics enables organisations to detect unusual activities, while formal insider threat response procedures, including disciplinary measures, establish a defined framework for enforcement (ISO 27001, 2022; CERT, 2021; Greitzer & Frincke, 2010). The safeguards protect against both negligent and malicious insider threats while they sustain ongoing surveillance of secure accounts.

3.3 Long-Term Controls: Months 9 -12

The period from month nine until month twelve of the project represents its final phase, which focuses on two main objectives. The organisation conducts regular threat hunting exercises, which follow MITRE ATT&CK and threat intelligence frameworks to detect upcoming malvertising and malware patterns, while penetration testing establishes the success of its security measures (MITRE, 2023; ENISA, 2020; Symantec, 2019). The annual staff refresher training, together with the policy reviews, establishes a framework which enables the organisation to adapt its procedures according to new regulations and developing security threats (ISO 27001, 2022; NIST CSF, 2018; Hahnagy, 2018). Standard operating procedures need to incorporate lessons learned from previous incidents to strengthen defence mechanisms against new attack strategies (Peltier, 2016).

The table provides a comprehensive overview of the recommended mitigation measures together with their twelve-month priority schedule. It displays the main activities which are linked to their respective priority levels and their required operational standards and reference materials, and a summary of management control systems which control operational activities and process improvements according to the strategic implementation plan that exists between Sections 3.1 to 3.3.

Control Area	Key Action	Priority (Months)	Table 1: Action Plan 3.4
Governance & Policy Enforcement	Comprehensive policy review, creation of risk register, management reporting lines, compliance audits	1-3	
Identity & Access Management	MFA for all accounts, role-based access control, access recertification	1-3	
Monitoring & Detection	SIEM deployment, centralised logging, real-time alerts, staff training	1-3	
Database & Server Security	SQL and web server hardening, automated patch management, network segmentation	4-8	
Endpoint Protection	Advanced EDR, content filtering, malware detection	4-8	
Insider Threat Mitigation	Privileged Access Management (PAM), behavioural analytics, insider response procedures	4-8	
Threat Hunting	MITRE ATT&CK exercises, threat intelligence feeds	9-12	
Staff Awareness & Policy Updates	Annual refresher training, policy review, lessons learned integration	9-12	

Financial and Resource Considerations

3.4.1 Initial Investment Requirements (Months 1 - 3)

The first phase of the mitigation strategy begins with establishing new governance structures, creating new policies and implementing essential security measures, which include Multi-Factor Authentication (MFA) and other basic security measures. The typical expenses associated with these security measures remain lower than the financial costs of implementing infrastructure-level security solutions. Organisations that need to implement Multi-Factor Authentication (MFA) can achieve this security measure through existing systems which manage identity and access without requiring extra hardware expenses, while this solution protects against credential theft.

The implementation of a Security Information and Event Management (SIEM) system requires an organisation to spend more money than its current security measures require. The need for licensing models and the log retention storage needs, together with the requirement to employ trained analysts who will supervise alert systems, leads to increased expenses for both capital and operational needs. The organisation should invest in monitoring capabilities because this investment helps to decrease attacker dwell time while it enhances incident response capability, which ultimately results in less data breach expenses for the organisation.

3.4.2 Infrastructure and Technical Control Costs (Months 4 - 8)

The second phase introduces higher-cost technical controls, which include Privileged Access Management (PAM) and Endpoint Detection and Response (EDR) solutions and network segmentation. The controls need enterprise-level subscriptions together with system reconfiguration and consultancy services to enable secure implementation.

The process of network segmentation requires organisations to upgrade their hardware, which includes updating firewalls and redesigning their network architecture to meet new requirements. The deployment of automated patch management solutions requires

organisations to dedicate resources for both integration work and testing procedures that ensure system uptime. The expenditures require high financial investment; however, they provide major protection against lateral movement attacks and privilege abuse, which attackers use to escalate their attacks. The organisation should treat these expenditures as planned capital expenses that will prevent future problems instead of treating them as emergency expenses.

3.4.3 Ongoing Operational and Recurring Costs (Months 9 - 12)

The last stage of the project brings ongoing costs that include regular security assessments and continuous threat detection, and yearly cybersecurity training programs. The process of penetration testing needs external experts, which creates consultancy expenses.

Organisations need to allocate internal staff or use third-party security services for their threat hunting and monitoring needs.

Security awareness programmes generate continuous expenditure but are critical in reducing phishing susceptibility and insider risk. The financial impact of regulatory penalties, litigation expenses, reputational damage and customer loss after a major data breach remains higher than these recurring expenses.

3.4.4 Cost–Benefit and Strategic Risk Perspective

The twelve-month mitigation roadmap should function as a strategic risk management initiative because it extends beyond its technical upgrade function when its complete financial effects are assessed. Industry analyses show that organisations save money through proactive security investments when they compare these costs against expenses required for post-breach remediation, which involves forensic investigations, legal fees and regulatory fines and system recovery and reputational rebuilding efforts. The proposed controls will result in immediate and midterm costs, but they will strengthen the organisation through their direct impact on its ability to withstand challenges and their support of regulatory requirements and development of trust with stakeholders.

3.5 Twelve-Month Cyber Security Cash Flow Forecast

To support the implementation of the proposed mitigation strategy, a financial forecast has been developed to distribute the required cybersecurity investments over a twelve-month period. This will enable Webb For U to manage its operations while improving its cybersecurity position. The financial schedule has been designed to ensure that the most important defensive strategies are implemented in the early stages of the mitigation program. The improvements to the infrastructure will be implemented in the later stages of the program. The first quarter will be dedicated to implementing identity protection strategies, improving governance, and implementing monitoring strategies. The first quarter is the most important as it will address the most immediate security risks that were identified during the investigation. The second quarter will be dedicated to improving the infrastructure, protecting the endpoints, and improving the network. The third quarter will be dedicated to implementing the monitoring strategies. The following table shows the distribution of the required cybersecurity investments.

Table 2: Cyber Security Implementation Cash Flow Forecast

Month	Security Measure	Estimated Cost (£)	Strategic Purpose
Month 1	IT policy review, governance framework, risk register development	500	Establish organisational security governance
Month 2	Multi-Factor Authentication implementation	600	Protect accounts from credential compromise
Month 3	SIEM deployment and log monitoring setup	2,000	Enable real-time threat detection
Month 4	Endpoint Detection and Response (EDR) deployment	1,500	Detect malware and rogue antivirus campaigns
Month 5	Network segmentation and firewall reconfiguration	1,200	Prevent lateral movement inside the network
Month 6	Automated patch management system	900	Reduce vulnerability exposure
Month 7	Privileged Access Management (PAM) solution	1,300	Control administrative account access
Month 8	Insider threat monitoring and behavioural analytics tools	800	Detect abnormal employee activity
Month 9	External penetration testing	2,000	Identify remaining security vulnerabilities
Month 10	Security awareness training programme	700	Reduce social engineering risks
Month 11	Independent cybersecurity audit	1,000	Evaluate effectiveness of implemented controls
Month 12	Threat intelligence subscriptions and monitoring improvements	600	Support proactive threat detection
Total Estimated Year-One Security Investment: £13,100			

4. Continuous Improvement, Compliance, and Future Threat Preparedness

4.1 Security Audits and Compliance Monitoring

The cybersecurity framework of Webb For U requires a security audit system that conducts regular assessments to test compliance with security standards. The organisation uses security audits to assess its compliance with established policies and procedures and technical controls.

Webb For U needs to create both scheduled audits and unplanned audits, which will assess all parts of their organisation, including network infrastructure, endpoint systems, web servers, and database management. Internal audits need to check whether users follow password policies and multi-factor authentication requirements and role-based access control rules.

Automated systems should be used for compliance monitoring as they can monitor compliance with regulatory standards, which include GDPR and PCI DSS, and all other industry-specific requirements that apply to digital advertising and client data management. Executives receive instant visibility of organisational hazards through real-time compliance dashboards, which also use audit logs for tracing essential activities that support forensic investigations according to NIST SP 800-53 2020.

4.2 Staff Training and Awareness Programs

Employees are the main protective barrier that defends organisations from cyber threats. The Webb For U organisation needs to implement a complete cybersecurity program, which requires ongoing staff training together with awareness programs to decrease their vulnerability against social engineering, phishing attacks and insider threats. Research shows that most security incidents involve human error or manipulation (Hadnagy, 2018).

The initiatives support secure password usage, malicious advertisement detection and proper sensitive data handling through their reinforcement of best practices. Staff members must understand how to report incidents and escalate problems while following the organisation's procedures for handling insider threats.

The organisation uses annual courses together with specific training programs that focus on different job roles to help employees remember what they learn while they develop the ability to handle new security threats. The training needs of developers, network administrators and database managers require additional instruction which focuses on secure coding practices, patch management techniques and intrusion detection methods (CIS, 2021).

4.3 Future Threat Intelligence Integration

The organisation needs to use threat intelligence as a vital element for making operational decisions and strategic decisions to achieve protection against new cyber threats. Organisations use threat intelligence to collect information about threats that exist and threats that will emerge, which they need to protect their operational environment (MITRE 2023).

The organisation needs to acquire both commercial and open-source intelligence feeds to identify patterns in malvertising operations and malware distribution, and the latest

exploitation methods used against SQL servers and web applications. To enable automatic detection of unusual activities and the automatic priority assignment function, threat intelligence needs to establish a connection with both incident response systems and security information and event management systems.

Webb For U combines threat intelligence with strategic planning to achieve technological alignment and future risk prediction while maintaining security budget control according to organisational goals (ENISA 2020).

4.4 Metrics and KPIs for Security Effectiveness

Webb For U needs to establish specific Key Performance Indicators (KPIs) together with measurement metrics which will apply to their technical operations and governance functions. The security incident detection and response capability of an organization can be evaluated through two metrics which are mean time to detect (MTTD) and mean time to respond (MTTR) and through two additional metrics which measure the number of security vulnerabilities that the organization has found and fixed and the percentage of employees who finished their required training and the organization's success in meeting its audit requirements (NIST CSF, 2018).

The operational KPIs system assesses how well organisations implement their policies, how they follow their access control policies and how ready they are to respond to security incidents. The governance KPIs system monitors three elements, which include the percentage of audits that have been completed, the number of risk register updates and the frequency of management reviews.

The executive team receives practical insights through regular metric reporting, which also enables organisations to enhance their performance continuously. Webb For U can establish its most important projects through the implementation of these KPIs into the organisation's risk management structure while using security infrastructure investments to demonstrate its responsibility to both stakeholders and regulators.

Conclusion

The security breaches at Webb For U showed that their organisation suffered from major weaknesses in three essential areas, which included their governance system and access control mechanisms, monitoring capabilities and policy enforcement systems. The organisation experienced security breaches because its technical security controls and procedural security controls failed to stop attackers who subsequently gained access to Microsoft SQL servers for distributing malicious advertising content. The organisation experienced greater security threats because its employees, through their negligence and poor password practices, created security vulnerabilities, while the organisation lacked proper monitoring and detection methods for insider threats.

The cybersecurity assessment found several identity management, network monitoring, endpoint protection, database security, and incident response aspects of the current cybersecurity plan which required improvements. The report proposed a twelve-month mitigation strategy which established priority implementation through recognised frameworks and defence-in-depth principles to minimise operational and financial, and reputational risks.

The recommended controls, which include SIEM monitoring and multi-factor authentication, network segmentation, staff awareness training and insider threat management, will enhance the organisation's capacity to safeguard against cyber threats while detecting and handling future security breaches. The proposed strategy delivers Webb For U an improved protective cybersecurity system, which enhances their ability to achieve long-term security improvement and restore trust among stakeholders.

References

- Armin Pelkmann and Armin Pelkmann (2014). *Threat Spotlight: 'Kyle and Stan' Malvertising Network Threatens Windows and Mac Users With Mutating Malware*. [online] Cisco Blogs. Available at: <https://blogs.cisco.com/security/talos/kyle-and-stan> [Accessed 13 Mar. 2026].
- Enisa (2016). *ENISA*. [online] Europa.eu. Available at: <https://www.enisa.europa.eu/>.
- ISO (2022). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. [online] Iso.org. Available at: <https://www.iso.org/obp/ui/en/#iso:std:iso-iec:27001:ed-3:v1:en>.
- MITRE (2025). MITRE ATT&CK. [online] Mitre.org. Available at: <https://attack.mitre.org/>.
- NIST (2025). *Cybersecurity Framework*. [online] National Institute of Standards and Technology. Available at: <https://www.nist.gov/cyberframework>.
- NIST (2017). NIST SP 800-63 Digital Identity Guidelines. [online] Nist.gov. Available at: <https://pages.nist.gov/800-63-3/>.
- NIST (2020). *Security and Privacy Controls for Information Systems and Organizations*. [online] csrc.nist.gov. Available at: <https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>.
- OWASP (2025). *OWASP Top Ten*. [online] owasp.org. Available at: <https://owasp.org/www-project-top-ten/>.
- Peltier, T.R. (2016). *Information Security Policies, Procedures, and Standards*. Auerbach Publications. doi: <https://doi.org/10.1201/9780849390326>.
- Sandhu, R., Coyne, E., Feinstein, H. and Youman, C. (1996). Role-Based Access Control Models. *IEEE Computer*, [online] 29(2), pp.38–47. Available at: <https://csrc.nist.gov/CSRC/media/Projects/Role-Based-Access-Control/documents/sandhu96.pdf>.
- SEI News. (2021). *CERT Insider Risk Management Symposium 2021 to Explore Balanced Approaches to Insider Risk*. [online] Available at: <https://www.sei.cmu.edu/news/cert-insider-risk-management-symposium-2021-to-explore-balanced-approaches-to-insider-risk/> [Accessed 2 Mar. 2026].
- Scarfone, K. and Mell, P. (2007). *Guide to Intrusion Detection and Prevention Systems (IDPS)*. [online] csrc.nist.gov. Available at: <https://csrc.nist.gov/pubs/sp/800/94/final>.
- www.scirp.org. (n.d.). *Von Solms, R. and Van Niekerk, J. (2013) From Information Security to Cyber Security. Computers & Security, 38, 97-102. - References - Scientific Research*

Publishing. [online] Available at:

<https://www.scirp.org/reference/referencespapers?referenceid=2904943>.

www.microsoft.com. (n.d.). *Cloud Security Services / Microsoft Security*. [online] Available at:

<https://www.microsoft.com/en-gb/security>.

AI Usage Declaration

Grammarly was used during the proofreading stage of this report to assist with grammar correction and language refinement. All content was reviewed and finalised by the author.

Appendix A – Immersive Labs Evidence

A total of 203 Immersive Labs were completed through the entire set of defensive cybersecurity assessments. The finished laboratories researched incident response methods, digital forensics techniques, malware detection processes, SIEM system monitoring, threat detection operations, vulnerability assessment procedures, and defensive security methods.

The practical exercises developed technical skills, which included threat detection skills, forensic investigation skills, network analysis skills, malware identification skills, log monitoring skills, and incident response procedure skills. The following sections contain evidence of completed labs together with supporting screenshots.

Evidence of Completed Labs

Cyber Defence	Completed	Total	Percentage
NIST – SPC for ISO(800-53)	22	22	100%
NIST – GSP in PCC (800-144)	10	10	100%
Windows Forensics Artifacts	10	10	100%
Introduction to Incident Response	8	8	100%
AI Fundamentals	9	9	100%
Threat Hunting - Theory	17	17	100%
MITRE ATT&CK	16	16	100%
OWASP Top 10 (2021)	13	13	100%
The OpenSCAP Project	7	7	100%
IoT & Embedded Devices	9	9	100%
Splunk	7	7	100%
Elastic Playground	4	4	100%
CTI First Principles	7	7	100%
Radare2	3	3	100%
Wireshark	9	9	100%
Introduction to Digital Forensics	6	6	100%
Web Log Analysis	6	6	100%
Introduction to PowerShell Deobfuscation	6	6	100%
Log Analysis	10	10	100%
Digital Forensics Process	9	9	100%
Secure Fundamentals	8	8	100%
Vulnerability Management	7	7	100%
Total	203	203	100%

Figure 1 Immersive Labs

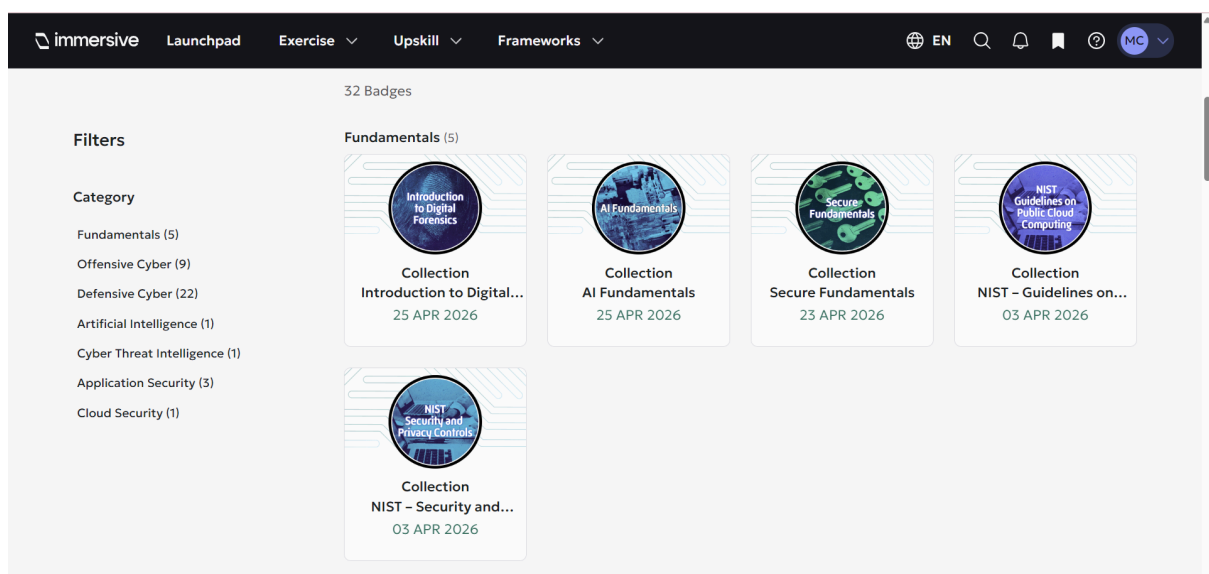


Figure 2 Immersive Labs Achievements

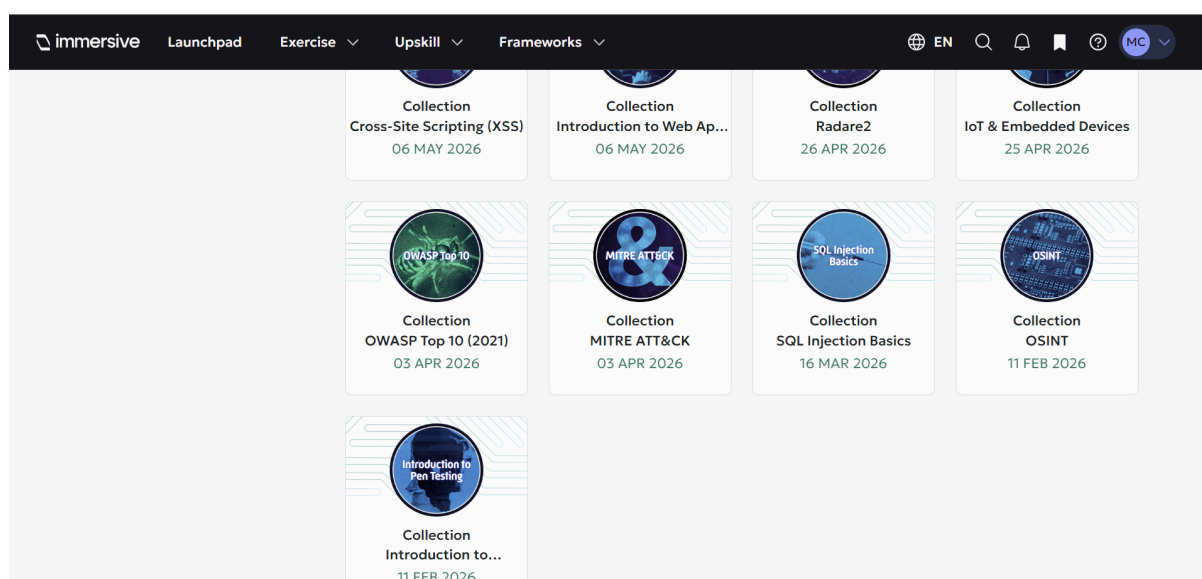


Figure 3 Immersive Labs Achievements

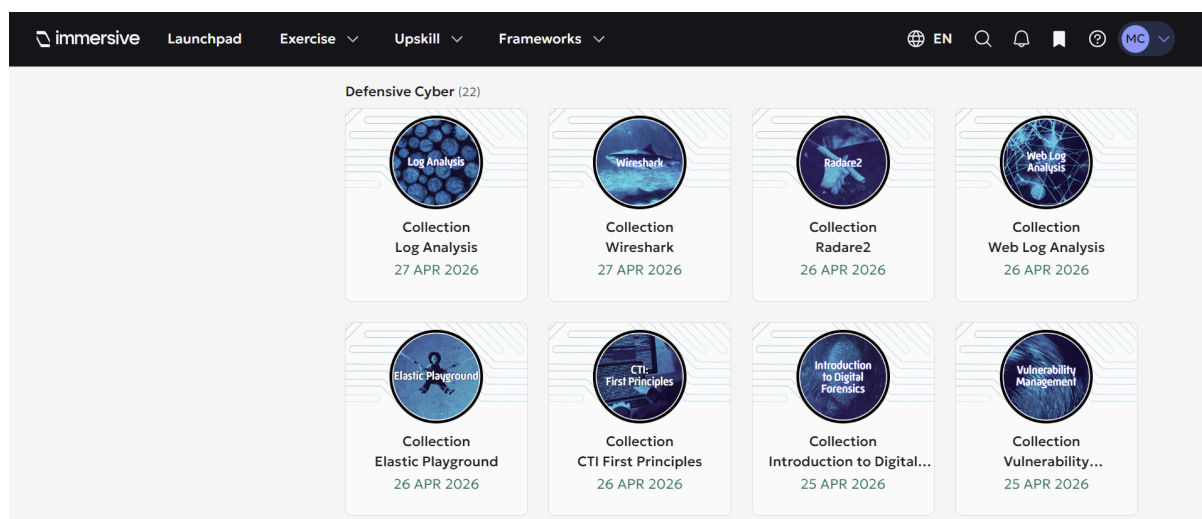


Figure 4 Immersive Labs Achievements

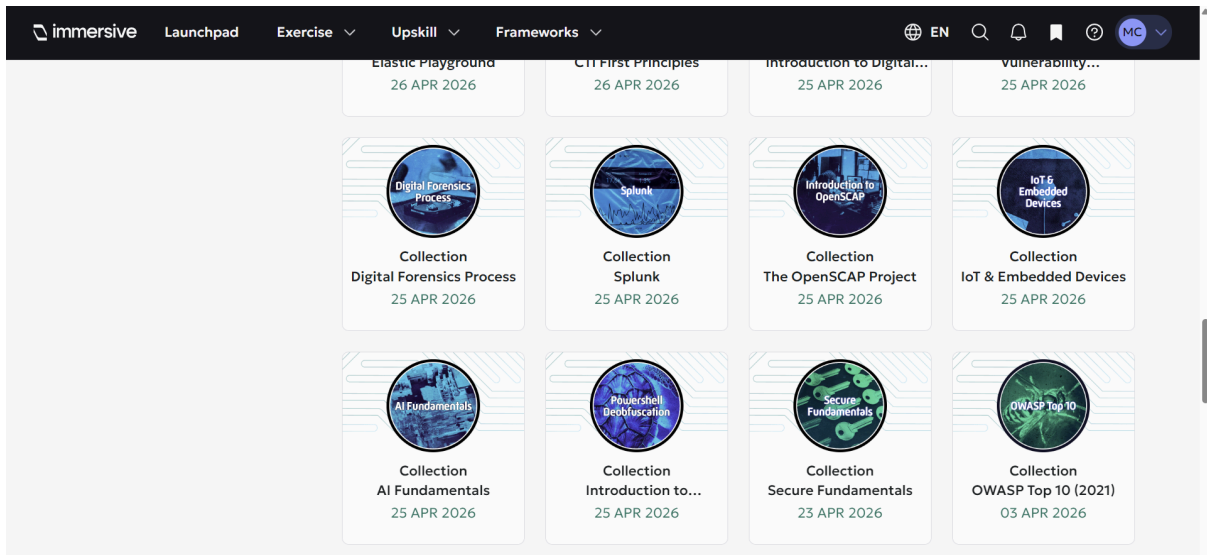


Figure 5 Immersive Labs Achievements

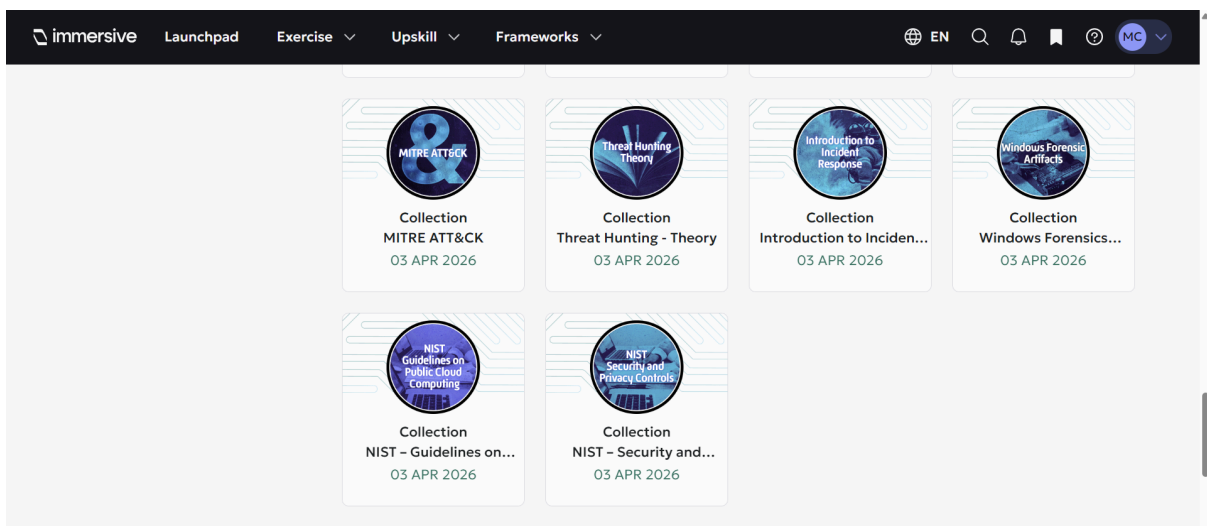


Figure 6 Immersive Labs Achievements

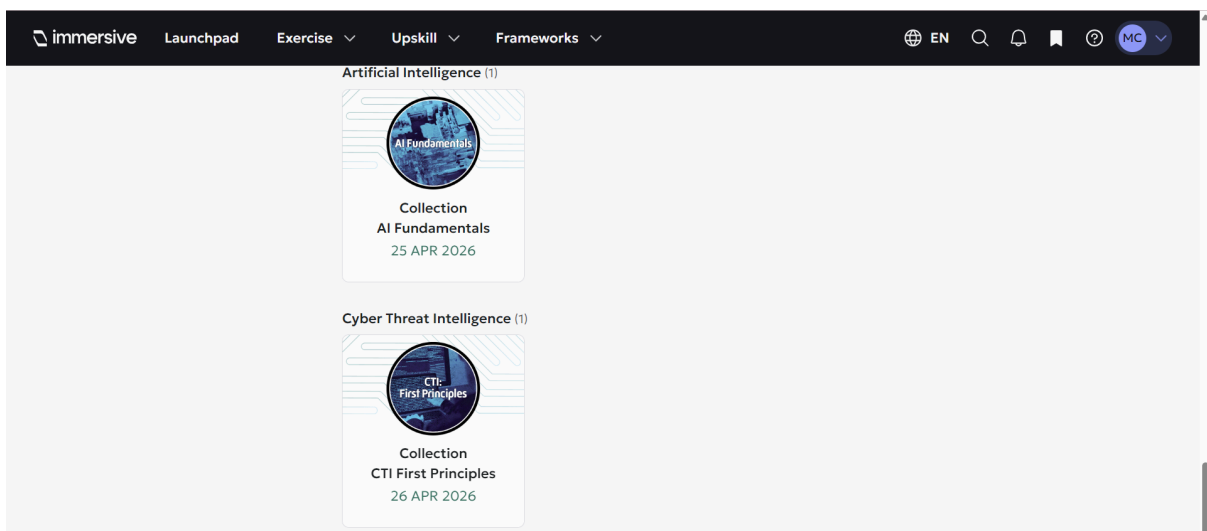


Figure 7 Immersive Labs Achievements

Practical Skills Developed

- Incident response and threat detection
- SIEM monitoring and log analysis
- Malware analysis and reverse engineering
- Digital forensics investigation
- Vulnerability assessment and system hardening
- Threat hunting and intrusion detection